ICDFA | GRC105 | WEEK 20

INCIDENT RESPONSE PLANNING

Northbridge Skills Institute — Ransomware Incident Response Assignment

Student: Ibrahim Abdullahi
Student ID: 2025/GCR/12720
Official email: grc2512720@students.icdfa.edu.ng
Course: GRC105 — Incident Management and Business Continuity
Word count: approximately 3,330 (including tables and references)
Submission: Six-task case analysis | All case details fictional

Contents

Task 1 — Detection, classification and initial assessment
Task 2 — Incident response policy, CSIRT and readiness
Task 3 — Incident response playbook, evidence and recovery
Task 4 — Communication and escalation
Task 5 — Tabletop exercise and improvement plan
Task 6 — Healthcare case analysis and reflection
References and authorship declaration

Framework and assumptions

The assignment follows the four teaching stages: preparation; detection and analysis; containment, eradication and recovery; and post-incident activity (International Cybersecurity and Digital Forensics Academy [ICDFA], n.d., slide 6). This is the course teaching model, not the structure attributed to NIST SP 800-61 Rev. 3. NIST Rev. 3 aligns incident response with CSF 2.0: Detect, Respond and Recover are the core incident response functions, supported by Govern, Identify and Protect, with improvement across all functions (Nelson et al., 2025).

All names, incident records, timestamps and response decisions are fictional. Evidence IDs E01–E08 refer to the assignment scenario. Planned collection, tests, communications and tabletop results are not presented as completed real-world activities.

TASK 1 — Detection, Classification and Initial Assessment

1.1 Incident facts and timeline

At 08:45 WAT on Day 0 (Monday), I would assume the Incident Response Lead role for Northbridge Skills Institute, which serves 1,800 learners and employs 90 staff. One hundred learners are due to sit an online examination at 11:00. The evidence suggests a critical ransomware event, but the entry point, attacker identity, scope and possible data theft are not yet established (ICDFA, n.d., slides 4, 9–10).

Evidence / time	Observed fact	Working interpretation and uncertainty
E01 · Day −1 16:40	Finance officer opened unexpected payroll attachment on FIN-PC07.	Possible phishing entry point; malicious execution not confirmed.
E02 · Day 0 01:15	Finance officer Microsoft 365 login from unfamiliar IP/new device.	Potential account misuse; MFA and user confirmation outstanding.
E03 · 01:35	svc_backup unusual remote administrator logons to FS01 and BAK01.	Possible lateral movement; could be legitimate scheduled administration.
E04 · 01:50	FIN-PC07 sent 1.2 GB by HTTPS to unfamiliar cloud storage.	Potential exfiltration; content and legitimacy unknown.
E05 · 02:00	FS01/LMS01 backup jobs reported success.	Success does not establish backup integrity or recoverability.
E06 · 08:30	Mass file changes on FIN-PC07; .locked files and ransom note on FS01.	Strong ransomware indicators; malware family unknown.
E07 · 08:40	LMS login page loads, but access and submissions fail.	Confirmed learning service disruption; LMS01 compromise not established.
E08 · 08:45	Contact list on FS01 unavailable; email trust unverified.	Use verified phones and alternative secure channels.

1.2 Severity and business impact

Initial classification: CRITICAL / SEV 1. The combination of encryption indicators, loss of access to shared resources, examination disruption, privileged-account anomalies and uncertain backups requires immediate CSIRT mobilisation and executive notification. Severity must be reviewed as facts change, not based on an assumed attacker identity or proven data theft (ICDFA, n.d., slide 10; Nelson et al., 2025).

Asset / function	Confidentiality	Integrity	Availability / priority
FS01 shared server	Learner and financial records may be exposed.	Files appear encrypted or altered.	Affected; urgent containment and clean recovery.
LMS01 portal	No confirmed disclosure.	Assessment integrity requires validation.	Learners cannot access or submit; exam at risk.
FIN-PC07	Possible upload; content unknown.	Mass file changes observed.	Isolate and investigate.
BAK01 / svc_backup	Privileged access could expose backups.	Backup trust not established.	Protect backup path before recovery.
Microsoft 365	Unfamiliar login needs validation.	Possible identity misuse.	Keep email trust under review.

1.3 Initial questions and next evidence

- Confirm FIN-PC07 process execution, attachment provenance, EDR alerts and file modification sequence.
- Review Microsoft 365 sign-in, MFA, device and session logs to verify E02.
- Correlate svc_backup logons, source hosts and approved change records for E03.
- Obtain proxy, DNS and transfer metadata for E04; determine whether learner information was included.
- Check FS01/BAK01 backup repositories and offline backup integrity in isolation; verify whether LMS01 itself is affected.
- Identify additional hosts, affected accounts, ransom-note details and scope; reassess severity if containment or evidence changes.

TASK 2 — Policy, CSIRT, RACI and Readiness

2.1 Incident response policy outline

Purpose: protect learners, staff, data and essential academic services through timely, evidence-based incident response. **Scope:** endpoints, servers, cloud identity, learning services, backups, third parties and all personnel. The Incident Response Lead may declare a Critical incident, activate the CSIRT, coordinate containment and direct evidence preservation. In emergencies, IT may immediately disconnect a clearly compromised endpoint, recording the action and notifying the lead. Restoration of critical academic services requires Director approval informed by technical and academic sign-off (ICDFA, n.d., slides 7–8, 14).

Use incident ID NSI-IR-001. Log all decisions, owners, timestamps, evidence sources and chain of custody. Use verified telephone contacts if FS01 or corporate email is unsafe. Legal/Privacy decides applicable formal notification duties. Conduct annual reviews and reviews following major incidents or exercises. Link the response plan to business continuity: the examination must not proceed on an unverified platform.

2.2 CSIRT and RACI

Roles: IRL = Incident Response Lead; SA = Security Analyst; DF = Digital Forensics Specialist; IT = IT Operations Lead; AO = Academic Operations Lead; LP = Legal/Privacy Adviser; CO = Communications Officer; DIR = Institute Director. Specialist forensic/legal support may be contracted because the internal technical team is small.

Activity	A (one accountable)	R (responsible)	Consulted / informed
Detection and triage	IRL	SA, IT	AO informed
Technical analysis	IRL	SA, DF	IT consulted
Containment	IRL	SA, IT	AO, LP consulted
Evidence handling	IRL	SA, DF	LP consulted
Stakeholder communications	IRL	CO	AO, LP consulted
Regulatory obligations	LP	LP	IRL, DIR consulted
Restoration approval	DIR	IT, AO	IRL, SA consulted
Closure and review	IRL	IRL, SA, IT	DIR informed

2.3 Preparedness gaps and controls

Gap / action	Owner / resources	Verification
No immutable network backups; offline backup aged	IT; protected/offline media and recovery environment	Quarterly isolated restore test with evidence.
EDR incomplete on servers	SA/IT; endpoint monitoring licences	Coverage report and detection test.
FS01-only incident contact list	IRL/CO; encrypted offline copies	Quarterly telephone-tree check.
svc_backup broad privilege	IT; PAM, least privilege, MFA where supported	Privilege review and login alert test.
Only 3 IT staff + 1 security analyst	DIR; external incident-response retainer	Executed agreement and contact test.
No restore tests for 90 days	IT; rehearsal schedule	Documented test outcomes and corrective actions.

TASK 3 — First 24-Hour Playbook and Recovery

3.1 First 60 minutes (Day 0, 08:45–09:45 WAT)

Window	Action and owner	Authority / evidence / completion check
08:45–08:50	IRL declares Sev 1, activates CSIRT, opens NSI-IR-001.	IRL; incident log and role acknowledgements.
08:50–08:55	CO/IRL use verified phone tree; prohibit untrusted email for incident coordination.	IRL; recipient and channel log.
08:50–09:05	IT isolates FIN-PC07 from network, preserving volatile evidence where feasible.	IRL; EDR state, host notes and isolation verification.
08:55–09:10	IT contains FS01 and limits spread; identify affected shares.	IRL; firewall/host logs and connectivity check.
09:00–09:15	IT/SA protect BAK01; review and restrict suspicious svc_backup sessions.	IRL; auth logs, session revocations and service dependency check.
09:05–09:20	SA reviews Microsoft 365 sessions and unfamiliar sign-in.	IRL; exported sign-in/MFA records and verified account status.
09:10–09:30	DF/SA preserve ransom note, endpoint alerts, file metadata and relevant logs.	IRL; chain-of-custody record and integrity checks.
09:20–09:35	SA examines E04 transfer metadata; LP notified of potential exposure.	IRL; evidence register and legal assessment request.
09:25–09:40	AO tests LMS impact without unsafe reopening; proposes exam contingency.	DIR approves postponement; learner plan ready.
09:40–09:45	IRL briefs Director on impact, uncertainty and decisions.	IRL; approved briefing and next update 10:30.

3.2 Remaining 23 hours

Period	Action / owner	Completion condition
09:45–12:00	DF/SA scope endpoints, privileged accounts, lateral movement and E04; preserve artefacts.	Correlated evidence timeline and updated affected-host list.
Before 11:00	AO/DIR decide examination postponement or independently verified alternative.	Decision recorded; learners informed via approved channel.
12:00–16:00	IT verifies backup copies in isolated environment, including offline Day −3 backup.	Integrity and restore test results; originals preserved.
16:00–20:00	IT/SA plan eradication: trusted reimage, patching, revoke tokens, rotate credentials.	Approved technical plan with service dependency check.
20:00–Day +1 04:00	IT restores essential identity/monitoring, FS01 and LMS01 in stages if validated.	Security, integrity and business acceptance tests passed.
Day +1 04:00–08:45	IRL/SA monitor for recurrence, reassess scope, report status and risks.	Decision log, monitoring summary and next-day recovery plan.

3.3 Evidence register and chain of custody

The following are planned collections, not completed acquisitions. Each collection should record UTC/WAT time, collector, source, method, SHA-256 hash calculated after acquisition, encrypted evidence location and custody transfers. Never invent hashes or mark evidence collected without confirmation (ICDFA, n.d., slides 10, 13).

Item	Planned source	Collector / purpose
EV-01	FIN-PC07 EDR telemetry, disk/memory as feasible	DF; entry point and encryption sequence.
EV-02	FS01 ransom note, file samples, server logs	DF; ransomware indicators and spread.
EV-03	Microsoft 365 sign-in and MFA records	SA; assess E02.
EV-04	Proxy/firewall/DNS/transfer logs	SA; investigate E04 and possible disclosure.
EV-05	FS01/BAK01 privileged-access logs	SA/DF; investigate E03.
EV-06	Backup job logs, repository metadata, restore errors	IT/DF; recoverability and backup trust.

3.4 Recovery priorities and assumptions

Proposed RTO/RPO targets below are planning assumptions, not scenario commitments. At 08:45 Day 0, the Day −3 17:00 offline backup is about 63 hours 45 minutes old. It cannot meet a four-hour RPO without additional clean sources. No service should return to production solely to meet an examination deadline (Cybersecurity and Infrastructure Security Agency [CISA] et al., 2023; Nelson et al., 2025).

Service	Proposed RTO	Proposed RPO	Release gate
Identity and monitoring	As early as safely possible	N/A	Known-good identity state, alerting and account controls.
FS01 shared server	12 hours	4 hours	Isolated restore, malware checks, integrity and owner sign-off.
LMS01 learning portal	8 hours	4 hours	Verified dependencies, safe assessment submissions and AO sign-off.
Finance workstation	24 hours	24 hours	Trusted rebuild and user validation.
Backup recovery path	8 hours to establish trusted path	N/A	Successful isolated restore test; no repository contamination.

If clean restoration succeeds, prioritise identity and monitoring, backup recovery capability, FS01, LMS01, then FIN-PC07. Continue enhanced monitoring for a proposed 72 hours, then complete post-incident review and track corrective actions. If backup tests fail, maintain academic workarounds and escalate revised recovery estimates.

TASK 4 — Communication and Escalation

4.1 Communication matrix

Stakeholder	Trigger	Owner	Primary / fallback channel	Approver	Frequency
Director / management	Sev 1; major decision	IRL	Secure briefing / verified phone	IRL for updates; DIR for decisions	Hourly initially
IT / security	Activation or new finding	IRL	Approved bridge / verified phone	IRL	Continuous; 30-min check-ins
Learners	Portal disruption; exam decision	CO	Verified website/portal / SMS	AO	On decision and change
Academic staff	Exam/ assessment impact	AO	Staff platform / phone tree	AO	Activation and changes
Service provider	Need specialist support	IT	Verified portal / emergency phone	IRL	At activation and as needed
Legal / privacy	Potential personal data breach	IRL	Secure channel / verified phone	IRL	Immediately; material changes
Employees	Operational restrictions	CO	Staff platform / SMS	IRL	Initial and material changes
Regulator, if required	Legally reportable breach	LP	Official portal / designated secure channel	DIR after LP review	Statutory schedule

4.2 Executive briefing (draft; Day 0 09:45 WAT)

> **To:** Institute Director and Management | **From:** Incident Response Lead | **Subject:** Initial Critical Incident Briefing. Northbridge Skills Institute is managing a suspected ransomware incident classified as Critical. At 08:30, mass file changes were detected on FIN-PC07, while encrypted-looking files and a ransom note were identified on FS01 (E06). Learners are unable to access learning materials or submit assessments through the portal (E07). Unusual Microsoft 365 sign-in activity, privileged logons and a 1.2 GB external transfer are under investigation (E02–E04). We have not established that personal data was stolen or that the backups are clean and recoverable. The CSIRT has been activated and is prioritising containment, evidence preservation, account review and backup validation. Management approval is requested to postpone the 11:00 examination if the platform cannot be independently verified as safe, authorise emergency external technical support and allocate recovery resources. We will avoid unverified restoration and communicate approved academic arrangements through trusted channels. The next management update is scheduled for 10:30 WAT, or earlier if a significant finding changes our assessment.

4.3 Learner notice (draft; issue only after postponement approval)

> Dear Learners, we are currently experiencing a technical disruption affecting access to learning materials and assessment submissions on the Northbridge Skills Institute portal. Our technical team is working to restore services safely. Due to this disruption, the online examination scheduled for 11:00 today has been postponed until further notice. A revised examination schedule will be shared through verified official channels once confirmed. Please do not attempt repeated submissions or use unofficial links claiming to provide alternative examination access. You do not need to take any further action at this stage. We understand the inconvenience and appreciate your patience. Please watch for updates on the official website or by SMS. Academic Operations Team, Northbridge Skills Institute.

4.4 Escalation and legal assessment

- Escalate Sev 1 immediately to IRL and Director; activate CSIRT.
- Escalate evidence of continuing compromise, privileged-account misuse or possible exfiltration immediately to IRL and LP.
- DIR approves business continuity decisions; AO verifies academic arrangements; CO publishes only approved messages.
- If email is unsafe, use verified phone calls, SMS and preapproved secure channels; record all contacts and decisions.
- Legal/Privacy establishes jurisdiction, controller/processor status, affected data, risk, recipients and deadlines; do not treat an operational service notice as a formal personal data breach notification.

The case does not state a jurisdiction. If Nigeria is assumed, section 40 of the Nigeria Data Protection Act 2023 requires notification to the NDPC within 72 hours of awareness of a personal data breach likely to result in risk to individuals' rights and freedoms; high-risk breaches require immediate communication to affected individuals. Legal/Privacy must validate applicability and calculate the clock from awareness of a qualifying breach, not automatically from incident declaration (Federal Republic of Nigeria, 2023, s. 40).

TASK 5 — Tabletop Exercise and Improvement Plan

5.1 Design and success measures

Exercise duration: 60 minutes. **Format:** individual role-play simulation, not a live team drill. **Participants simulated:** IRL, SA, DF, IT, AO, LP, CO and DIR. **Objectives:** test escalation, unsafe-restoration resistance, breach assessment, backup fallback, crisis communication and privileged access containment (ICDFA, n.d., slides 8, 12–13).

Time	Inject / activity	Key simulated response
0–10	Brief roles, facts and Sev 1 status	IRL activates team; owners confirm.
10–20	Management demands LMS reopening before exam despite unverified backup	IT/SA advise against unsafe restore; DIR considers postponement.
20–35	Attacker claims 1,800 records and threatens publication in 12 hours; screenshot unverified	DF preserves claim; SA investigates E04; LP assesses breach.
35–45	Latest network backup test fails: unreadable snapshot	IT preserves error; test protected offline copy in isolation.
45–50	Social media says exam cancelled; journalist asks about exposure	CO/AO issue approved status; no unverified data-theft assertion.
50–55	Additional inject: svc_backup attempts further BAK01 admin login	IT/SA restrict sessions and reassess scope.
55–60	Debrief and action assignment	IRL documents gaps and owners.

Success criterion	Target	Individual simulation outcome
Escalation	Sev 1 and roles within 10 minutes	Addressed in opening briefing.
Decision speed	All five injects documented within 5 minutes	Five decisions recorded in allocated periods.
Recovery safety	No unverified restoration	Met in simulated decisions.
Communications	Approved management, learner, media responses	Proposed; not sent.
Privacy/evidence	LP escalation and preservation	Included; not performed.
Continuity	Safe exam alternative	Postponement proposed/approved in scenario.

5.2 Simulated decision log

Inject	Decision / owner	Rationale	Communication and effect
Minute 10	DIR: reject unsafe restore; postpone if necessary	Integrity and security outweigh deadline.	AO/CO notify learners; continuity plan activated.
Minute 20	IRL: preserve claim; investigate possible disclosure	Screenshot and attacker claim are unverified.	LP/DIR alerted; scope expanded.
Minute 35	IRL: isolate restore test of protected offline copy	Network snapshot unreadable.	DIR/AO updated; RTO/RPO reassessed.
Minute 45	IRL: release approved status and holding statement	Avoid rumours and unsupported assertions.	CO uses official channels; message consistency improved.
Minute 50	IRL: restrict svc_backup access and examine privileged accounts	Possible persistence threatens recovery.	IT/SA/DIR informed; containment expanded.

5.3 Evaluation and corrective action plan

All six criteria were addressed in the written role-play. This is a self-assessment, not measured performance by actual staff or a successful technical recovery test. Weaknesses identified include management pressure, lack of backup assurance, uncertain data exposure, communication fragility, limited staffing and privileged-account risk.

Priority	Action	Owner	Target	Evidence of completion
Critical	Protected/immutable backup plus quarterly restore tests	IT	30 days	Configuration and successful isolated restore report.
Critical	Privileged access review and monitoring	IT	14 days	Reviewed permissions, alert test and credential controls.
High	Breach assessment/notification procedure	LP	21 days	Approved procedure and assessment template.
High	Emergency communication templates and channel test	CO	14 days	Approved templates and documented test.
High	EDR/monitoring on critical servers	SA	30 days	Coverage report and alert test.
High	Offline incident contact list	IRL	7 days	Verified copy and call-tree test.
Medium	External IR/forensics retainer	DIR	45 days	Signed agreement and tested contacts.
Medium	Role-specific exercise and training programme	IRL	60 days	Attendance, debrief and tracked actions.

Complete the written tabletop review within five working days. For a real incident, hold a formal post-incident review within ten working days of stabilisation (the teaching deck recommends within two weeks of closure). Owners implement actions; IRL verifies evidence and tracks closure; DIR oversees Critical actions (ICDFA, n.d., slide 12).

TASK 6 — Case Study Analysis and Critical Reflection

The healthcare ransomware case on slide 16 concerns a 2,500-employee organisation compromised through a phishing attachment. A Ryuk variant persisted and moved laterally for about 72 hours before encryption. The slide reports that EDR alerted on Day 4, critical systems returned within 72 hours, and full restoration took seven days (ICDFA, n.d., slide 16).

Three response strengths stand out. First, the incident response team was activated immediately after detection, supporting coordinated decisions. Second, the organisation isolated affected systems and network segments, helping contain the attack. Third, verified offline backups enabled recovery without paying the ransom. These outcomes show the value of preparation, trained responders and tested recovery arrangements.

However, two issues deserve closer examination. The malware operated undetected for roughly three days, indicating a detection gap. Also, although the slide states that no patient data exfiltration was confirmed, it does not describe the evidence or limitations behind that conclusion. A confident assessment would require endpoint and server forensic records, database access logs, proxy/firewall/DNS and cloud transfer records, investigation of unusual outbound traffic, and checks for missing logs. Even then, incomplete visibility may prevent an absolute claim that nothing was stolen.

Restoring critical systems within 72 hours means priority clinical services were brought back first. Seven-day full restoration includes remaining systems, data validation, security hardening, testing and normal operational handover. These are different recovery milestones, not contradictory claims.

I would transfer two changes to Northbridge. The first is routine testing of protected offline backups: Northbridge has not tested either recovery route in 90 days, and its latest network backup failed in the tabletop simulation. The second is stronger network segmentation and server monitoring to detect lateral movement earlier and reduce spread. These align with ransomware response guidance (CISA et al., 2023).

After the tabletop, I would revise my decision to test the disconnected backup immediately after network restoration failed. The original should first be protected, relevant compromise indicators assessed, and a copy tested in an isolated environment. This would reduce the chance of contaminating a valuable recovery source. Overall, the case shows that fast restoration matters, but trustworthy evidence and safe recovery matter just as much.

References

Cybersecurity and Infrastructure Security Agency, Federal Bureau of Investigation, Multi-State Information Sharing and Analysis Center, & National Security Agency. (2023). *#StopRansomware guide*. https://www.cisa.gov/resources-tools/resources/stopransomware-guide

Federal Republic of Nigeria. (2023). *Nigeria Data Protection Act, 2023* (s. 40). https://ndpc.gov.ng/wp-content/uploads/2024/03/Nigeria_Data_Protection_Act_2023.pdf

International Cybersecurity and Digital Forensics Academy. (n.d.). *Incident response planning* (GRC105, Week 20, slides 1–18) [Teaching slides].

Nelson, A., Rekhi, S., Souppaya, M., & Scarfone, K. (2025). *Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile* (NIST SP 800-61 Rev. 3). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-61r3

Authorship and assistance acknowledgement

I am responsible for the content of this submission, which is a fictional academic case analysis. In line with ICDFA policy, I disclose that generative AI tools assisted this work: ChatGPT (OpenAI) supported drafting and document organisation, and Claude (Anthropic) supported formatting and final editing. I have reviewed and validated the scenario interpretations, source references, proposed timelines and recovery targets. No real-world investigation, system restoration, notification or tabletop exercise was conducted.